Выпускная квалификационная работа

Устинов И. А., БИСО-01-21

Содержание

ВВЕДЕНИЕ **2**

1 ТЕОРЕТИКО-МЕТОДИЧЕСКИЕ ОСНОВЫ ПРОЕКТИРОВАНИЯ СИСТЕМЫ ЗАЩИТЫ ОТ ВРЕДОНОСНОЙ СЕТЕВОЙ АКТИВНОСТИ С ИСПОЛЬЗОВАНИЕМ ПОВЕДЕНЧЕСКОГО ПРОФИЛИРОВАНИЯ **4**

1.1 Анализ актуальных векторов сетевых атак 4

1.2 Анализ решений по защите пользователей от подозрительной сетевой активности 6

1.2.1 Мобильные анализаторы трафика 8

1.2.2 Облачные сервисы фильтрации и мониторинга на уровне DNS 8

1.2.3 DNS-серверы для локальных сетей 9

1.2.4 Мобильные средства защиты от угроз 9

1.2.5 Веб-браузеры со встроенной фильтрацией 10

1.3 Ключевые методы и технологии обнаружения вредоносной активности в трафике 12

1.3.1 Глубокий анализ пакетов 12

1.3.2 Потоковый анализ 13

1.3.3 Анализ на основе сигнатур 13

1.3.4 Применение песочниц 13

1.3.5 Поведенческий анализ и машинное обучение 13

1.4 Централизованный сбор и извлечение признаков сетевого трафика 16

2 РАЗРАБОТКА АРХИТЕКТУРЫ СИСТЕМЫ **19**

2.1 Серверная архитектура 19

2.1.1 Сбор данных о сетевых подключениях 20

2.1.2 Анализ сетевого трафика 20

2.1.3 Хранение данных 22

2.1.4 Клиент-серверное взаимодействие 22

2.1.5 Поведенческое профилирование 22

2.2 Клиентская часть 24

ВВЕДЕНИЕ

Актуальность темы. В современном мире невозможно обойтись без выхода в Интернет: общение, развлечения, образование – все это можно найти в онлайн-пространстве. Огромное количество людей в качестве инструмента для доступа в сеть выбирают мобильный телефон. В последнее время наблюдается резкий рост использования сервисов по созданию виртуальной частной сети, однако данная технология применяется пользователями бездумно, многие обыватели не задумываются, как такой способ подключения способен навредить их информационной безопасности. Рядовой пользователь может не догадываться о том, что используемый сервис пересылает личную информацию злоумышленнику. На фоне этого имеет место увеличение объемов скомпрометированной информации и утекших данных, это подтверждает статистика компании F6 за 2025 год: 760 млн строк с данными российских пользователей попали в утечки [1].

Степень научной разработанности. На сегодняшний день вопросам обнаружения аномалий в сетевом трафике и проектирования систем обнаружения вторжений посвящено большое количество научных работ. Глубоко изучены методы сигнатурного анализа и машинного обучения для выявления подозрительных действий в сети. Вместе с тем большинство существующих решений ориентированы на корпоративный сектор и требуют значительных вычислительных ресурсов и участия квалифицированных специалистов для правильной интерпретации журналов событий.

Проблема исследования. Отсутствие эффективного и удобного для рядового пользователя решения, которое обеспечивало бы комплексную защиту устройств от вредоносной сетевой активности.

Объектом исследования являются системы мониторинга сетевых соединений и защиты пользователей от вредоносной сетевой активности.

Предметом исследования выступают механизмы выявления аномалий в сетевом трафике с использованием поведенческого профилирования.

Целью выпускной квалификационной работы является разработка многоуровневой системы защиты пользователей от вредоносной сетевой активности с использованием поведенческого профилирования.

Для достижения цели поставлены и решены следующие задачи:

1) Проанализировать актуальные векторы сетевых атак;
2) Провести анализ существующих решений в области систем по обнаружению подозрительной активности в сетевом трафике;
3) Исследовать алгоритмы машинного обучения для реализации механизма поведенческого профилирования;
4) Изучить работу анализатора сетевого трафика Zeek;
5) Спроектировать серверную и клиентскую архитектуру системы;
6) Выполнить программную реализацию спроектированной многоуровневой системы защиты;
7) Провести тестирование разработанной системы и анализ результатов ее работы.

Методы исследования. Анализ существующих решений в области систем по обнаружению подозрительной активности в сетевом трафике, комплексный анализ современных векторов сетевых атак, разработка конвейера обработки данных и пользовательского интерфейса.

Научная новизна. Предложена многоуровневая система защиты, комбинирующая метод поведенческого профилирования со статическим анализом индикаторов компрометации.

Практическая значимость. Результаты работы позволяют внедрить комплексное решение для защиты пользователей, состоящее из серверного анализатора и мобильного приложения. Система автоматически перехватывает трафик, выявляет подозрительную активность, оповещает пользователя о потенциально нежелательном трафике через мобильное приложение.

Структура работы. Пояснительная записка состоит из введения, исследовательского раздела, технологического раздела, заключения, списка использованных источников и приложений. В исследовательском разделе рассматриваются теоретические основы построения системы защиты от вредоносной сетевой активности с использованием поведенческого профилирования: анализ актуальных векторов сетевых атак и решений по защите пользователей от подозрительной сетевой активности, традиционные подходы к выявлению подозрительной активности в сетевом трафике, применение алгоритмов машинного обучения для поиска аномалий в сетевом трафике, централизованный сбор и извлечение признаков сетевого трафика, взаимодействие с пользователем. В специальном разделе выполняется разработка архитектуры многоуровневой системы защиты пользователей от вредоносной сетевой активности с использованием поведенческого профилирования. В технологическом разделе будет представлена практическая реализация системы, описание программной структуры, настройка компонентов и результаты тестирования.

Глава 1

ТЕОРЕТИКО-МЕТОДИЧЕСКИЕ ОСНОВЫ ПРОЕКТИРОВАНИЯ СИСТЕМЫ ЗАЩИТЫ ОТ ВРЕДОНОСНОЙ СЕТЕВОЙ АКТИВНОСТИ С ИСПОЛЬЗОВАНИЕМ ПОВЕДЕНЧЕСКОГО ПРОФИЛИРОВАНИЯ

1.1 Анализ актуальных векторов сетевых атак

Несмотря на совершенствование средств защиты информации, именно конечный пользователь является главной целью злоумышленников. Ввиду роста использования российскими пользователями инструментов для организации защищенного доступа [2], прослеживается увеличение числа инцидентов информационной безопасности. Анализ актуальных векторов сетевых атак демонстрирует, что злоумышленники стали больше эксплуатировать доверие и техническую неосведомленность пользователей.

По данным компании Positive Technologies, с июля 2024-го по сентябрь 2025 года на долю России пришлось от 14% до 16% всех успешных кибератак в мире [3]. На рисунке ниже представлена динамика успешных кибератак на организации и частных лиц в России (рис. 1.1).

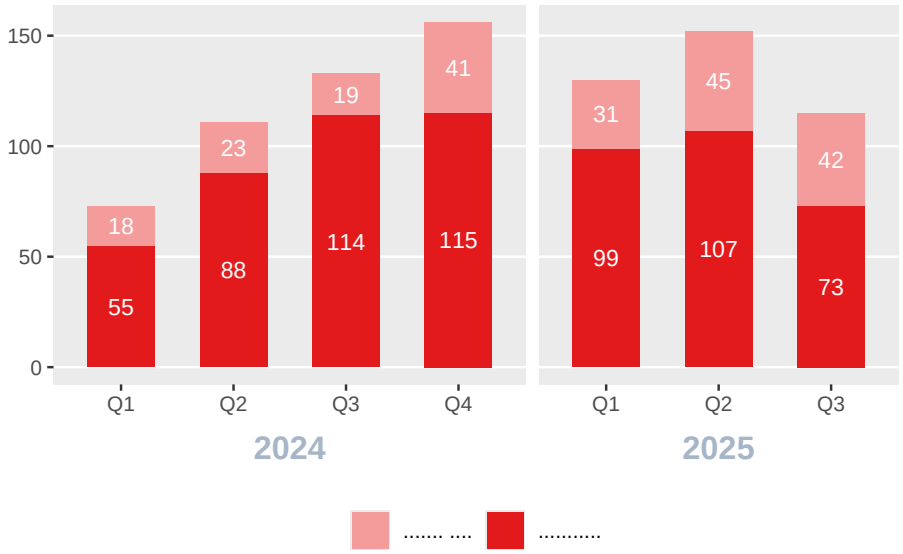


Рисунок 1.1: Динамика успешных кибератак

Исходя из данной динамики, можно сделать следующий вывод относительно частных лиц: наблюдается заметное увеличение числа атак на пользователей. Если в первой половине 2024 года фиксировалось 18-23 инцидента за квартал, то данный показатель вырос до 31-45 инцидентов в квартал за тот же временной промежуток в 2025 году, что на 53% больше.

Анализ гистограммы успешных атак относительно методов (рис. 1.2) показывает, что среди векторов воздействия преобладает социальная инженерия, на которую приходится 96%, однако стоит обратить внимание на второй по величине метод – использование вредоносного программного обеспечения. Исходя из данных наблюдений, складывается следующий вывод – злоумышленники при воздействии на частных лиц делают акцент на человеческом факторе и доверчивости пользователей.

Рассматривая распределение долей успешных атак с использованием вредоносного программного обеспечения относительно частных лиц (рис. 1.3), можно заметить преобладание следующих типов: вредоносное программное обеспечение для удаленного управления, шпионское программное обеспечение, банковский троян. Данная статистика свидетельствует о том, что злоумышленники стремятся к максимально скрытному присутствию на устройстве жертвы, незаметно для пользователя крадут его личную информацию и пересылают ее на удаленный

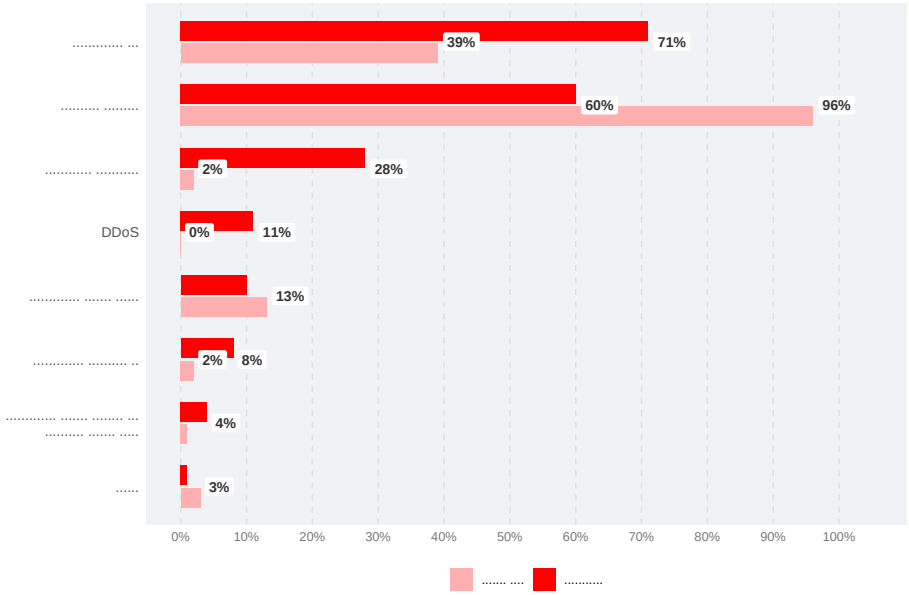


Рисунок 1.2: Методы кибератак на организации и частные лица

сервер для дальнейшей продажи.

Вывод по параграфу 1.1

Подводя итог анализу актуальных векторов кибератак, можно сделать следующий вывод относительно частных лиц: имеется тенденция к росту числа инцидентов. При атаке на пользователя злоумышленники делают акцент на человеческом факторе и технической неосведомленности граждан. Преступники стремятся к максимально незаметному присутствию на устройстве жертвы, об этом говорят преобладающие типы вредоносного программного обеспечения, а именно инструменты для удаленного управления, шпионские приложения и банковские трояны.

1.2 Анализ решений по защите пользователей от подозрительной сетевой активности

Для противодействия описанным векторам атак и защиты конечных пользователей от скрытого вредоносного воздействия применяются различные системы защиты. Архитектуру системы мониторинга сетевой активности можно представить в виде компонентов:

- Агент - установленная на отслеживаемых хостах программа, которая собирает данные о сетевой активности и отправляет их на сервер для

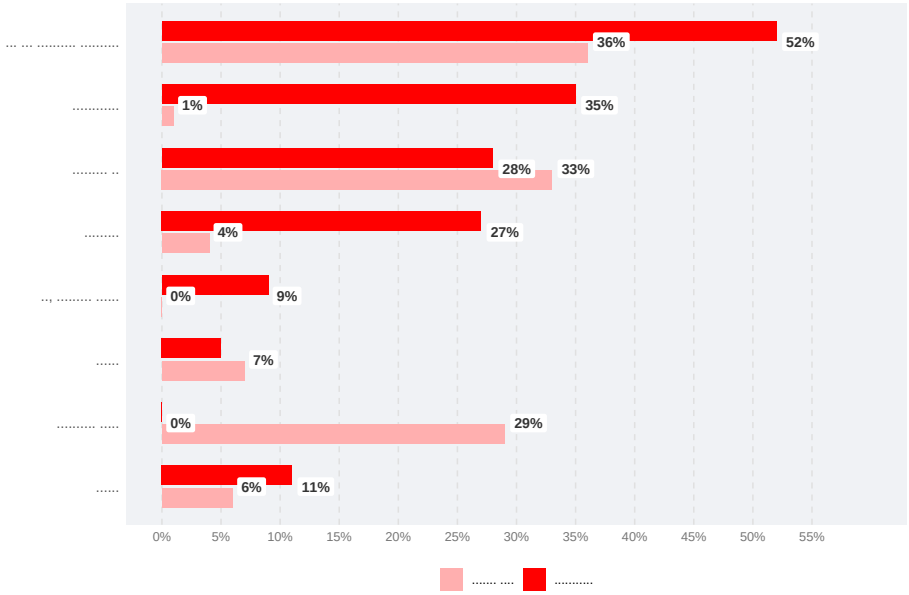


Рисунок 1.3: Типы используемого ВПО в атаках на организации и частных лиц

анализа;

- Сервер - центральный компонент системы, выполняющий анализ данных, полученных от агентов;
- База данных - централизованная хранилище, которое накапливает собранные данные о состоянии сети;
- Визуализация и управление - интерфейс, который прдоставляет пользователям доступ к информации о мониторинге и управлению настройками, чаще всего представлен в виде веб-приложения.

В процессе мониторинга сетевой активности допустимо выделить ключевые уровни контроля, зависящие от точки перехвата пакетов:

- Уровень конечной точки: мониторинг трафика и активности программ осуществялется локально на устройстве клиента;
- Уровень внутренней сети: трафик отслеживается в ммоент его прохождения через коммутатор, который связывает устройства внутри периметра;
- Уровень сетевого периметра: анализ осуществляется на границе между корпоративной инфраструктурой и Интернетом.

С учетом выделенных уровней перехвата пакетов, на сегодняшний день имеется большой выбор программных средств и архитектурных подходов, направленных на мониторинг сетевой активности пользователей.

1.2.1 Мобильные анализаторы трафика

Данные программные решения устанавливаются на смартфон клиента. Из-за соображений безопасности приложения не имеют прямого доступа к сетевому трафику телефона. Для решения проблемы подобные программные продукты используют встроенный системный механизм создания виртуальной частной сети, другими словами, мобильные приложения создают на устройстве виртуальный сетевой интерфейс и перенаправляют все сетевые пакеты через себя, то есть анализ метаданных соединений производится непосредственно в памяти устройства. Примерами такого типа приложений могут служить: GlassWire и PCAPdroid.

Главным преимуществом решения является высокая степень конфиденциальности, поскольку данные не покидают пределы устройства и пользователю не требуется доверять свой трафик сторонним серверам.

У такого подхода имеется несколько существенных недостатков. Так как выполнение анализа пакетов, сверка метаданных с индикаторами компрометации из баз данных осуществляется непосредственно на смартфоне, это создает избыточную нагрузку на процессор и оперативную память мобильного устройства, что вызывает заторможенность в работе и повышенный расход энергии аккумулятора. Также стоит отметить, что в современных устройствах имеются встроенные механизмы операционной системы, которые направлены на оптимизацию заряда батареи и могут принудительно выгружать фоновую службу анализатора из памяти.

1.2.2 Облачные сервисы фильтрации и мониторинга на уровне DNS

При использовании данного типа реализации нет необходимости в установке какого-либо стороннего программного обеспечения на устройство клиента. Пользователь прописывает в настройках мобильного телефона адрес защищенного DNS-сервера, в свою очередь, сервис сверяет все доменные имена, которые запрашивает устройство, с индикаторами компрометации из баз данных. Примерами таких сервисов могут служить: AdGuard DNS и NextDNS.

Ключевым преимуществом такого метода является простота внедрения и нелувое влияние на производительность смартфона, так как все операции по выявлению и блокировке вредоносных узлов выполняются на далненных серверах.

Данный подход имеет ряд проблем. Стоит обратить внимание на отсутствие возможности глубокого анализа содержимого сетевых пакетов, так как система не имеет доступа к полным URL-адресам, путям запросов и передаваемому контенту. Также необходимо учитывать наличие единой точки отказа – при сбоях в сети провайдера DNS пользователь может полностью потерять доступ к интернету.

1.2.3 DNS-серверы для локальных сетей

Данный подход обеспечивает защиту клиента путем развертывания сервиса фильтрации непосредственно внутри локальной сети пользователя. Для реализации необходимо установить специализированное программное обеспечение на постоянно включенное устройство, которому в локальной сети назначается статический IP-адрес.

При стандартной конфигурации маршрутизатор автоматически передает подключаемым устройствам адрес DNS-сервера интернет-провайдера или свой собственный. После внедрения сетевого фильтра описанный выше принцип работы изменяется – всем клиентам в качестве основного DNS-сервера назначается внутренний IP-адрес развернутого сетевого фильтра. В результате все устройства сети перестают обращаться к DNS-серверам провайдера напрямую и направляют трафик через общий узел, который отсекает рекламу и известные вредоносные сайты. Самым популярным программным решением, основанным на представленном подходе, является Pi-hole.

Преимуществом такого архитектурного метода выступает безагентная защита всех устройств сети одновременно. Это позволяет эффективно защищать IoT-устройства, так как на большую часть такого оборудования технически невозможно установить классическое программное обеспечение для защиты.

Рассмотренное решение обладает рядом ограничений. Слабым местом такого архитектурного метода является зависимость от одного локального сервера. Если устройство, на котором установлено фильтрующее приложение, выключится, зависнет или получит другой IP-адрес, клиенты могут потерять доступ к сайтам. Помимо этого, стоит обратить внимание на факт функционирования защиты только внутри домашнего периметра, то есть при отключении смартфона от домашней сети и переходе на мобильную передачу данных, устройство выходит из локальной сети, следовательно, перестает защищаться фильтром.

1.2.4 Мобильные средства защиты от угроз

Данный класс приложений фокусируется на комплексной защите устройства пользователя, они позволяют выявлять вредоносные программные решения, пресекать переход клиента на фишинговый ресурс и контролировать целостность системы. Примером такого программного решения может служить Kaspersky Endpoint Security. Работа подобных решений строится на комбинации трех уровней проверки:

- Анализ приложений и файлов. Средство защиты сканирует файлы в хранилище устройства, вычисляет хеш-суммы и сверяет их с базами сигнатур известных вредоносных программных обеспечений. Также могут дополнительно оценивать набор разрешений, которые запрашивает мобильное приложение;
- Оценка уязвимостей устройства. Решение проверяет конфигурацию операционной системы, например, включенный режим отладки по USB

или разрешение на установку пакетов из неизвестных источников;

- Проверка ссылок и беспроводных сетей. Для реализации защиты от фишинга и вредоносных сайтов данные программные решения используют системные службы специальных возможностей, помимо этого анализируются параметры беспроводных сетей на подозрительные настройки;

Ключевым преимуществом применения данного инструмента является тщательная проверка файлов и внутренних настроек устройства. Это помогает вовремя находить уже известные угрозы, предотвращать эксплуатацию системных уязвимостей и блокировать установку вредоносного программного обеспечения.

Использование подобных мобильных средств защиты имеет ряд ограничений. Из-за строгой изоляции приложений данные средства проверяют сами файлы на смартфоне, сверяя контрольные суммы по базам данных для поиска совпадений, но не способны полноценно анализировать сетевой трафик других программ. Возможна ситуация, при которой на устройство пользователя было установлено вредоносное приложение, зафиксированное антивирусом как легитимное. Исходя из вышеуказанной проблемы изоляции – средство защиты не сможет заметить факт передачи таким программным обеспечением личных данных на удаленный сервер злоумышленника. Также стоит обратить внимание на необходимость постоянной фоновой активности такого типа решений – из-за чего происходит нагрузка на процессор.

1.2.5 Веб-браузеры со встроенной фильтрацией

Средства защиты такого вида представляют собой приложения для просмотра веб-сайтов, в архитектуру которых интегрированы инструменты блокировки подозрительных ресурсов и рекламы. Примерами таких решений могут выступать: Brave Browser и DuckDuckGo Privacy Browser.

При открытии любого ресурса браузер предварительно сверяет URL-адрес с базами вредоносных сайтов, переводит соединение на протокол HTTPS, блокирует выполнение сторонних скриптов. Также используется механизм песочниц, который изолирует каждую вкладку от операционной системы и друг от друга, то есть, если вредоносный код выполнится на веб-странице, он останется внутри вкладки и не сможет получить доступ к файлам на устройстве или к процессам операционной системы.

Ключевым преимуществом данного решения является использование технологии песочниц, которая строго изолирует каждую открытую вкладку друг от друга и от операционной системы устройства. Благодаря такой архитектуре, даже если вредоносный код будет успешно выполнен на скомпрометированной веб-странице, результат работы останется внутри конкретной вкладки и не сможет получить несанкционированный доступ к файловой системе смартфона.

Данный подход имеет ограничения. Подобный веб-браузер контролирует и

фильтрует сетевой трафик исключительно внутри приложения и не влияет на работу остальных программ, то есть весь трафик, создаваемый этими приложениями, проходит мимо системы защиты, минуя фильтры.

В таблице ниже (табл. 1.1) представлен сравнительный анализ рассмотренных архитектурных подходов.

Таблица 1.1: Сравнительный анализ решений по защите от подозрительной сетевой активности

Подход	Примеры решений	Основные преимущества	Ключевые недостатки
Мобильные анализаторы трафика	GlassWire, PCAPdroid	Анализ соединений непосредственно на устройстве через локальный VPN-интерфейс.	Высокая нагрузка на ЦП, ОЗУ, батарею, риск принудительной выгрузки службы операционной системой.
Облачные DNS-сервисы	AdGuard DNS, NextDNS	Отсутствие необходимости устанавливать стороннее ПО на смартфон пользователя.	Невозможность глубокого анализа пакетов, наличие единой точки отказа на стороне провайдера.
Локальные DNS-серверы	Pi-hole	Централизованная фильтрация вредоносного трафика для всех устройств в пределах сети.	Защита не функционирует при выходе из защищенного периметра, зависимость от локального узла.
Мобильные средства защиты от угроз	Kaspersky Endpoint Security	Комплексный контроль: сканирование файлов, проверка уязвимостей ОС и беспроводных сетей.	Невозможность полноценного анализа трафика других программ из-за строгой изоляции приложений, постоянная фоновая нагрузка.

Подход	Примеры решений	Основные преимущества	Ключевые недостатки
Браузеры со встроенной фильтрацией	Brave, DuckDuckGo	Встроенный механизм песочниц, изоляция вкладок, принудительное использование HTTPS.	Мониторинг и фильтрация трафика ограничиваются исключительно рамками самого приложения-браузера.

Вывод по параграфу 1.2

Подводя итог анализу существующих решений по защите пользователей от подозрительной сетевой активности, можно сделать вывод о том, что ни один из рассмотренных подходов не обеспечивает полноценного и удобного мониторинга всего трафика устройства. Решения, которые устанавливаются непосредственно на смартфон, создают высокую нагрузку на процессор и увеличивают расход заряда аккумулятора телефона, помимо этого их работа ограничивается операционной системой путем выгрузки средства защиты из фона и строгой изоляцией приложений. Веб-браузеры со встроенным фильтром обрабатывают соединения исключительно внутри себя, локальные серверы перестают защищать смартфон при выходе за пределы домашней сети, а облачные DNS-сервисы не способны выполнять глубокий анализ пакетов.

1.3 Ключевые методы и технологии обнаружения вредоносной активности в трафике

Выбор архитектуры определяет только место перехвата трафика, однако не решает задачу поиска угроз. Поэтому необходимо определить наиболее эффективный метод для обнаружения вредоносной активности в полученных сетевых пакетах. Обнаружение вредоносной сетевой активности требует применения комплекса технологий, так как ни один отдельной взятый инструмент не обеспечивает абсолютной защиты. Выбор конкретного метода или их комбинации зависит от множества факторов, например, архитектуры сети, вычислительных мощностей сервера. В данном разделе рассматриваются базовые принципы работы этих методов, их ключевые преимущества и ограничения.

1.3.1 Глубокий анализ пакетов

Метод позволяет заглядывать внутрь сетевых пакетов и анализаровать их содержимое до уровня приложений, другими словами, если злоумышленник передает файлы по HTTP, глубокий анализ пакетов может извлечь эти файлы и

отправить на анализ в другую систему. Ограничением данного подхода является зашифрованный трафик, пакеты которого невозможно проанализировать.

1.3.2 Потоковый анализ

Вместо анализа каждого пакета по отдельности система агрегирует информацию о всем потоке целиком. Он показывает, какие узлы взаимодействуют между собой, как меняется распределение нагрузки и в каких сегментах сети растет активность. Анализ такого типа показывает себя эффективно для обнаружения аномалий в объеме, например, резкий рост исходящего трафика с конкретного хоста.

1.3.3 Анализ на основе сигнатур

Принцип работы подхода заключается в сопоставлении параметров и содержимого сетевых пакетов с заранее сформированной базой данных известных атак и уязвимостей. При обнаружении точного совпадения параметров трафика с индикаторами система фиксирует инцидент. Ключевым преимуществом данного метода выступает минимальный уровень ложноположительных срабатываний при обнаружении известных векторов атак. Стоит отметить существенный недостаток такого подхода – невозможность выявления ранее неизвестных угроз до момента обновления базы данных. Также можно выделить подтип сигнатурного анализа – применение черных и белых списков. Данный подход позволяет администраторам сети самостоятельно формировать и настраивать правила фильтрации с учетом специфики инфраструктуры или внутренних регламентов организации. Несмотря на простоту реализации механизма, он имеет существенный недостаток – необходимость постоянной актуализации правил при каждом изменении в сетевой топологии. Помимо этого, такой подход оказывается неэффективным, если злоумышленник скомпрометирует узел, который уже находится в белом списке.

1.3.4 Применение песочниц

Технология анализа подозрительных объектов в изолированной среде. Если система мониторинга сетевого трафика выявляет подозрительный файл, она может отпраавить этот элемент в песочницу для проверки - там файл выполняется в виртуальной среде. По поведению файла можно сделать вывод о вредоносности без использования сигнатур.

1.3.5 Поведенческий анализ и машинное обучение

Суть данного метода заключается в сборе данных о трафике в безопасный период и построении профиля нормально поведения. Затем система в реальном времени сравнивает текущий трафик с созданной конфигурацией - любое отклонение фиксируется как подозрительное. При использовании методов машинного обучения с целью выявления аномалий в сетевом трафике устраняются некоторые ограничения и проблемы анализа на основе сигнатур, например, неспособность

выявления ранее неизвестных угроз и зависимость от регулярного обновления баз данных индикаторов компрометации. Алгоритмы машинного обучения способны выявлять новые векторы атаки, адаптироваться к их постоянным изменениям и эффективно находить отклонения от нормального поведения [4].

Имеются два основных метода обучения модели:

1) Обучение с учителем – это метод, который использует размеченные данные для обучения моделей. Для работы такого типа алгоритмов используются данные с заранее заданными метками и цель процедуры – найти закономерности, которые позволят точно предсказывать эти индикаторы для новых данных [5]. Ключевым преимуществом применения такого подхода является высокая точность классификации при наличии качественно размеченных данных. Главный недостаток этого метода в контексте сетевой безопасности заключается в непрерывном видоизменении векторов атак, поэтому собрать абсолютно точную и актуальную базу данных для обучения практически невозможно.
2) В обучении без учителя модель получает данные без меток, и ее задача заключается в самостоятельном выделении группы данных. Этот метод полезен, когда задача состоит в поиске неожиданных и скрытых закономерностей в большом объеме информации [5]. Однако у такого метода имеется недостаток – текущий подход может создавать большой объем ложных срабатываний ввиду того, что любое отклонение от нормы может быть ошибочно зафиксировано как угроза.

Одним из методов обучения без учителя является алгоритм изолирующий лес. Метод строит ансамбль случайных бинарных деревьев, где данные рекурсивно делятся по случайным признакам и порогам. Подход эксплуатирует свойство аномалий: они находятся далеко от плотных областей распределения и требуют меньше операций для изоляции. Нормальные точки, расположенные в плотных областях, изолируются глубже в дереве, в свою очередь аномалии изолируются ближе к корню. На каждом шаге алгоритм случайно выбирает признак и порог между минимальным и максимальным значением этого признака в текущем подмножестве данных. Пространство делится на два региона, процесс повторяется рекурсивно для каждого региона до достижения условия остановки.

На рисунке ниже показана визуализация принципа изоляции в изолирующем лесу (рис. 1.4). Левая панель демонстрирует изоляцию аномалии одним разбиением, правая панель показывает необходимость множественных разбиений для изоляции нормальной точки внутри плотного кластера.

Ниже представлена таблица для сравнения методов, которые были упомянуты ранее (табл. 1.2).

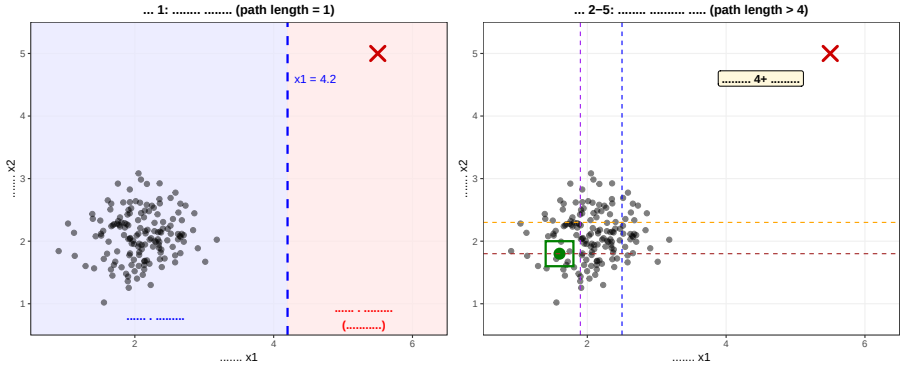


Рисунок 1.4: Принцип изоляции аномалий и нормальных точек в алгоритме Isolation Forest

Таблица 1.2: Сравнительный анализ методов обнаружения подозрительной активности

Метод	Принцип работы	Ключевые преимущества	Основные ограничения
Глубокий анализ пакетов (DPI)	Детальная инспекция содержимого пакетов до уровня приложений	Глубокая видимость передаваемых данных, высокая точность	Слепота к зашифрованному трафику (HTTPS/TLS)
Потоковый анализ	Агрегация метаданных о сетевых соединениях	Низкая нагрузка на сеть, выявление аномалий в объеме трафика	Отсутствие анализа полезной нагрузки
Сигнатурный анализ	Поиск точных совпадений с базой известных индикаторов угроз	Минимальное число ложных срабатываний, высокая скорость	Неспособность выявлять атаки нулевого дня
Песочницы	Запуск подозрительных объектов в изолированной среде	Точное определение вредоносности по реальному поведению	Задержка в анализе, высокие требования к ресурсам

Метод	Принцип работы	Ключевые преимущества	Основные ограничения
Машинное обучение	Построение профиля нормального поведения и поиск отклонений	Выявление скрытых зависимостей и ранее неизвестных угроз	Риск ложных срабатываний

Вывод по параграфу 1.3

Проведенный анализ методов обнаружения вредоносной активности в сетевом трафике показывает, что ни одна из технологий не обеспечивает абсолютное выявление аномалий. Глубокий анализ пакетов и сигнатурный метод, гарантируют высокую точность выявления известных угроз, однако уязвимы перед зашифрованным трафиком и атаками нулевого дня. Внедрение алгоритмов машинного обучения и поведенческого анализа позволяет компенсировать эти ограничения за счет выявления скрытых закономерностей и адаптации к новым векторам атак, однако остается риск ложных срабатываний.

1.4 Централизованный сбор и извлечение признаков сетевого трафика

Надежность рассмотренных методов машинного обучения напрямую зависит от качества и полносты обрабатываемой информации. Для корректной работы механизма обнаружения вторжений на основе машинного обучения необходимы данные о сетевой активности, на которых будет обучаться модель. Существуют два подхода к перехвату трафика: установка специализированного агента и использование технологии виртуальной частной сети для маршрутизации трафика на выделенный сервер.

Разработка агента является трудоемкой задачей, требующей адаптации под различные операционные системы. Использование VPN-конфигурации позволяет направить весь пользовательский трафик через выделенный сетевой интерфейс сервера, в частности применение OpenVPN гарантирует изоляцию трафика клиента от сервера, что позволяет системе анализа получить полную информацию о метаданных сетевых пакетов пользователей.

В качестве инструмента для извлечения метаданных из сетевого трафика рассматривается Zeek – программный комплекс с открытым исходным кодом для анализа трафика в сети [6]. К основным функциям и особенностям технологии можно отнести:

- Генерация большого набора логов;
- Обнаружение различных видов атак и аномалий в сети;

- Помимо функциональности «из коробки», Zeek представляет собой полностью настраиваемую и расширяемую платформу для анализа трафика. Пользователям предоставляется предметно-ориентированный язык сценариев для решения произвольных аналитических задач;

Каждый лог-файл, генерируемый инструментом, содержит в себе определенную сетевую активность: HTTP-сессии, DNS-запросы, TLS-соединение, информацию о сертификатах. На рисунке ниже представлен полный перечень возможных журналов событий, которые способна генерировать данная платформа (рис. 1.5).

В системе мониторинга сетевой активности Zeek предусмотрена возможность использования пользовательских плагинов – специализированных программных компонентов, которые расширяют базовый функционал анализатора сетевой активности. В качестве наиболее популярных плагинов можно выделить:

- Geoip-conn – данное расширение позволяет дополнить журнал событий conn.log информацией о геолокации трафика (код страны, область, город, широта, долгота)
- Zeek-intelligence-feeds – функционал данного плагина заключается в автоматическом сборе данных об индикаторах компрометации из публичных источников. Встроенный в Zeek анализатор проверяет каждый сетевой пакет на соответствие собранным данным. При обнаружении совпадения соответствующее событие фиксируется в специализированном лог-файле intel.log.

Вывод по параграфу 1.4

Таким образом, используя OpenVPN и Zeek можно сформировать конвейер данных: VPN обеспечивает прозрачный перехват пользовательского трафика, а расширяемая архитектура Zeek преобразует сырые пакеты в структурированные лог-файлы, которые можно использовать для анализа и обучения модели машинного обучения для проведения поведенческого анализа.

Выводы по первой главе

Таким образом, материалы исследовательского раздела формируют целостную теоретическую и методическую базу для дальнейшей разработки. В разделе рассмотрены актуальные векторы сетевых атак, решения по защите пользователей от подозрительной сетевой активности, традиционные подходы к выявлению аномалий, применение алгоритмов машинного обучения для поиска угроз, централизованный сбор и извлечение признаков сетевого трафика. Полученные выводы используются далее при построении специального раздела, где выполняется разработка многоуровневой системы защиты пользователей от вредоносной сетевой активности с использованием поведенческого профилирования.



Рисунок 1.5: Структура лог-файлов Zeek

Глава 2

РАЗРАБОТКА АРХИТЕКТУРЫ СИСТЕМЫ

Разрабатываемая система представляет собой программный комплекс, состоящий из серверной части и клиентской, которая реализована в виде мобильного приложения. На рисунке ниже показана ее схема (рис. 2.1).

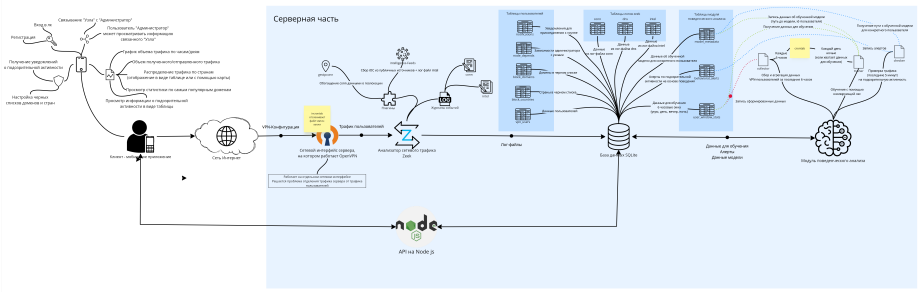


Рисунок 2.1: Схема системы

2.1 Серверная архитектура

Серверная часть выполняет полный цикл обработки данных - от захвата трафика до взаимодействия с мобильным клиентом. Логически данную область системы можно разделить на несколько компонентов:

1. Сетевой интерфейс, на котором расположен OpenVPN - необходимо для обособления сетевого трафика пользователей от серверного;
2. Анализатор Zeek - данный компонент служит инструментом для формирования журналов событий с информацией о сетевых соединениях

подключенных пользователей. Также средство предоставляет плагины, которые позволяют обогащать собранную информацию сведениями об индикаторах компрометации и геолокации Ip-адресов;
3. База данных SQLite - средство для хранения информации;
4. REST API - реализует взаимодействие между клиентом и сервером;
5. Модуль поведенческого профилирования - компонент, реализующий поведенческий анализ;

2.1.1 Сбор данных о сетевых подключениях

Ранее было упомянуто про техники сбора информации о сетевых подключениях: использование виртуальной частной сети и создание специализированного агента, который будет передавать данные о сетевой активности на удаленный сервер. При реализации данной архитектуры будет использоваться второй метод, это обусловлено сложностью разработки агента для различных операционных систем. В качестве решения для создания частной виртуальной сети выбран инструмент OpenVPN. Данный выбор обоснован принципом работы программного решения, оно пропускает весь трафик через отдельный сетевой интерфейс, благодаря чему система анализа получает возможность просматривать весь трафик пользователей. Таким образом, Zeek отслеживает и записывает информацию о метаданных соединений, принадлежащих клиентам. В контексте рассматриваемой системы возможно наличие нескольких пользователей, в связи с чем возникает задача идентификации трафика конкретного клиента из общего. Таким образом, для решения проблемы можно создать скрипт, который будет запускаться каждый раз при изменениях в файле status-server.log, который содержит информацию о идентификаторе клиента, его ip-адрес, а запуск программы производить с помощью incrontab, исполняющий код по событиям файловой системы.

2.1.2 Анализ сетевого трафика

Для сбора метаданных сетевого трафика используется инструмент Zeek. Далее описаны его возможности в контексте разрабатываемой системы.

2.1.2.1 Журналы и отчеты

Одним из главных преимуществ данной технологии является генерация большого набора журналов событий. Из огромного числа лог-файлов можно выделить следующие:

- conn.log - является одним из наиболее важных источников информации о сетевом трафике, создаваемых Zeek. В нем фиксируется каждое соединение, которое проходит через систему мониторинга. Журнал предоставляет базовую информация о сетевых потоках на транспортном и сетевом уровнях. Каждая запись содержит следующие ключевые метрики: универсальный идентификатор сессии, который позволяет связать запись в

conn.log с информацией из других журналов; ip-адреса и порты участников текущего взаимодействия; длительность соединения; количество байт, которые были переданы или получены; состояние соединения;
- dns.log - журнал, который фиксирует все DNS-запросы и ответы.

2.1.2.2 Расширение функционала

В системе мониторинга сетевой активности Zeek предусмотрена возможность использования пользовательских плагинов, позволяющие расширять базовый функционал анализатора. Для определения геолокации IP-адресов возможно применение API сторонних сервисов, например, VirusTotal, однако большинство подобных платформ предоставляют доступ на платной основе. Применяя расширение geoip-conn можно дополнить журнал событий conn.log следующей информацией:

- Код страны
- Регион
- Город
- Широта
- Долгота

Указанный плагин использует базу данных GeoLite2, которая выполняет сопоставление IP-адресов с их географическим положением. Стоит обратить внимание, что система мониторинга zeek является мощным анализатором сетевого трафика, а не системой обнаружения вторжений. Основная цель данного инструмента заключается в извлечении и структурировании метаданных о сетевой активности. В стандартной конфигурации анализатор не содержит встроенный список индикаторов компрометации и фиксирует лишь факт установки соединения. Существует возможность расширения функционала путем применения специального дополнения, обеспечивающего взаимодейтсвие Zeek с внешними источниками, которые содержат базы данных актуальных индикаторов компрометации - Zeek-Intelligence-Feeds. Функционал данного расширения заключается в автоматическом сборе данных из публичных источников, далее встроенный в zeek анализатор проверяет каждый сетевой пакет на соответствие собранным индикаторам. При обнаружении совпадения соответствующее событие фиксируется в специальном лог-файле intel.log. Плагин обрабатывает следующие типы индикаторов компрометации:

- Ip-адреса;
- Доменные имена;
- URL-адреса;
- Хеши и имена файлов;
- Адреса электронных почт.

Таким образом, применение данного расширения позволяет выявлять по сетевым индикаторам следующие классы угроз:

- Вредоносное программное обеспечение;

- Фишинговые атаки;
- Сетевые атаки;
- Утечки данных;
- Ботнет-активность;
- Потенциально нежелательные программы.

Помимо этого Zeek способен “из коробки” работать с базой данных SQLite, то есть инструмент автоматически вносит информацию о соединениях в базу данных. Под каждый лог-файл создается отдельная таблица.

2.1.3 Хранение данных

Лог-файлы, генерируемые Zeek, содержат большой объем информации, однако их анализ в исходном текстовом формате не всегда эффективен. Для упорядочивания и систематизации полученных данных целесообразно использование реляционной базы данных. Как было упомянуто ранее анализатор имеет функционал работы с базой данных SQLite, поэтому целесообразно при реализации использовать именно эту технологию для хранения информации.

2.1.4 Клиент-серверное взаимодействие

Для обеспечения взаимодействия пользователя с накопленными в базе данных сведениями требуется реализация серверного интерфейса, предоставляющего доступ к этим данным по сети. В качестве такого интерфейса выбран REST API – архитектурный стиль взаимодействия между клиентом и сервером, используя протокол HTTP. Он позволяет приложениям обмениваться данными, используя стандартные методы. В качестве платформы для реализации REST API можно использовать Node.js – инструмент с открытым исходным кодом для работы с языком JavaScript. Для взаимодействия приложения с API необходимо реализовать endpoint-ы – конечная точка сервиса, к которой клиентское приложение обращается для выполнения определенных операций или получения данных.

2.1.5 Поведенческое профилирование

Модуль поведенческого профилирования можно разделить на 3 взаимосвязанных компонента:

- Агрегация исторических данных;
- Обучение математической модели;
- Мониторинг трафика в режиме реального времени.

Все необходимые данные для обучения модели и работы модулей располагаются в соответствующих таблицах в базе данных SQLite.

2.1.5.1 Модуль сбора статистики

Для формирования базовой линии нормального поведения пользователя применяется модуль сбора статики, который необходим для излечения сырых записей о сетевых соединениях из соответствующих таблиц базы данных и агрегирования их в фиксированные исторические окна размером в 6 часов. В процессе сборе вычисляются следующие абсолютные метрики:

- Общее количество соединений;
- Объем переданного и полученного трафика в байтах;
- Количество уникальных IP-адресов и портов назначения;
- Средняя длительность сессии.

Извлеченные за данный временной интервал данные сохраняются в отдельную таблицу базы данных с привязкой к конкретному дню недели и временному слоту. Перед передачей данных в алгоритм машинного обучения они проходят обязательный этап математической обработки. Система обучается на больших исторических интервалах длинной по 6 часов, однако при этом мониторинг текущего трафика в реальном времени происходит короткими отрезками, например, каждые 5 минут, следовательно, алгоритм может ошибочно классифицировать 5-минутный отрезок трафика как аномалию из-за того, что итоговые цифры оказались намного меньше тех, что ему были предоставлены при обучении. Для решения образовавшейся проблемы система переводит абсолютные значения в формат интенсивности - общее количество делится на длину временного окна в секундах. В итоге такой подход позволяет модели машинного обучения адекватно оценивать плотность и характер сетевой активности пользователя вне зависимости от того, за какой временной промежуток она была собрана. Особое внимание в процессе подготовки данных уделяется обработке временного контекста. Традиционное представление времени в виде порядковых номеров создает проблему для алгоритмов машинного обучения, например, дню недели “понедельник” соответствует числовое значение 1, а “воскресенье” - 7, для обучаемой модели данные значения отдалены друг от друга, однако в реальности эти дни недели следуют непрерывно друг за другом. Для устранения данного разрыва применяется метод тригонометрического кодирования циклических признаков - метод, используемый в машинном обучении для представления циклических данных, таких как временные ряды или периодические признаки [7]. Для кодирования циклических данных можно использовать следующие формулы (2.1 - 2.2):

$$x_{sin} = \sin\left(2\pi * \frac{x}{P}\right) \tag{2.1}$$

$$x_{cos} = \cos\left(2\pi * \frac{x}{P}\right) \tag{2.2}$$

где:

- x: значение циклического параметра (например, понедельник = 1);

- P: период цикла (например, 7 - количество дней в неделе);
- xsin и xcos: закодированные значения, которые передаются в модель

2.1.5.2 Модуль обучения

Обучение модели запускается для каждого активного пользователя при условии наличия достаточного объема исторической выборки. В качестве основного алгоритма выявления аномалий применяется изолирующий лес, объяснение данного выбора представлено ранее. Обученная модель сохраняется в файловую систему сервера, путь к файлу фиксируется в базе данных.

2.1.5.3 Модуль мониторинга

Детектирование аномалий в режиме реального времени представляет собой непрерывный процесс оценки сетевой активности пользователей, направленный на выявление отклонений от сформированной базовой линии нормального поведения. Мониторинг осуществляется путем периодического сканирования трафика активных пользователей виртуальной частной сети каждые N минут. Если алгоритм классифицирует текущий вектор как подозрительный, сетевая активность признается аномальной, система создает соответствующую запись в таблице базы данных.

Вывод по параграфу 2.1

В ходе проектирования серверной архитектуры системы мониторинга сетевой активности сформирован концепт программного комплекса, серверная часть которого выполняет полный цикл обработки данных – от захвата трафика до взаимодействия с мобильным клиентом. Анализатор zeek сканирует сетевой интерфейс, обслуживающий трафик пользователей, подключенных через виртуальную частную сеть, для каждого его журнала событий создается отдельная таблица в базе данных SQLite. Также сервер обогащает собранные записи сведениями об индикаторах компрометации и геолокации IP-адресов. Доступ клиента к обработанных данным осуществляется через REST API. Подсистема поведенческого профилирования использует алгоритм машинного обучения “изолирующий лес” для непрерывного анализа трафика и детектирования аномалий в режиме реального времени.

2.2 Клиентская часть

В качестве инструмента взаимодействия пользователя с системой мониторинга стоит рассматривать мобильное приложение, так как оно обеспечивает непрерывный доступ к информации, то есть в случае обнаружения подозрительной сетевой активности пользователь может быть мгновенно проинформирован, например, с помощью push-уведомлений. Кроме того, современные мобильные операционные системы имеют встроенную поддержку управления VPN-конфигурациями, что значительно упрощает процесс подключения устройства к выделенному серверу.

Также по состоянию на июль 2026 года доля мобильного трафика составляет подавляющее большинство – 65,39%, тогда как на настольные компьютеры приходится лишь 33,21% (рис. 2.2) [8].

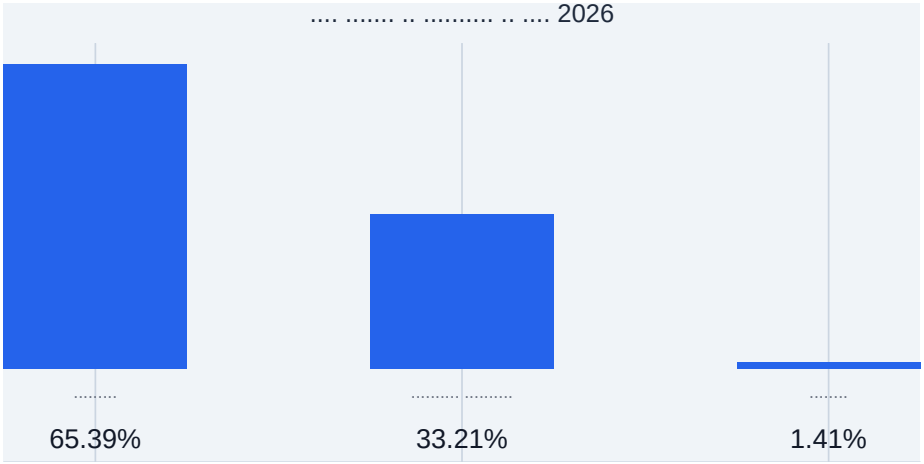


Рисунок 2.2: Доля трафика по платформам за июль 2026

Ретроспективный анализ за годовой период подтверждает стабильность распределения доли трафика по платформам (рис. 2.3) [8].

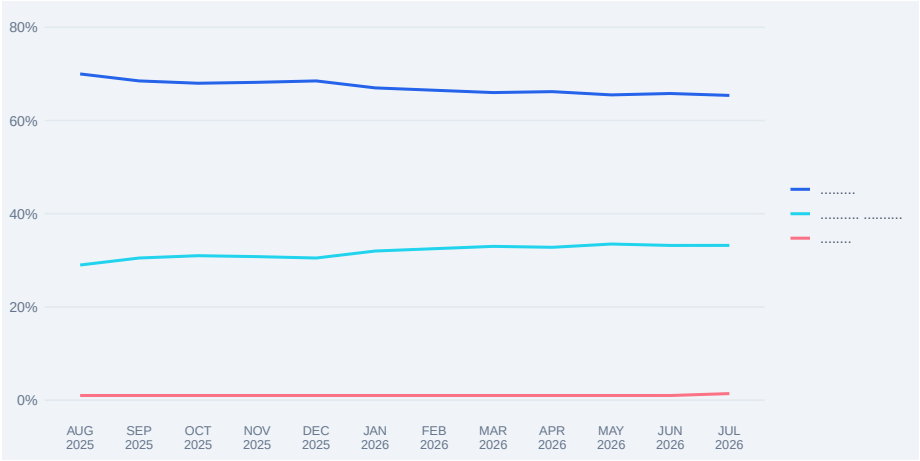


Рисунок 2.3: Динамика распределения трафика по платформам

Для обеспечения качественного взаимодействия с пользователем архитектура клиентского приложения должна базироваться на следующих принципах:

- Использование визуализации и агрегации данных. Анализатор сетевого трафика генерирует журналы событий, которые тяжело просматривать,

поэтому эти данные необходимо преобразовывать в интуитивно понятные графические элементы, например, в мобильном интерфейсе можно предоставлять пользователю агрегированную статистику: графики объемов входящего и исходящего трафика, визуальное представление стран взаимодействия на карте мира или списки наиболее посещаемых доменов.

- Управление ограничениями. Система должна предоставлять пользователю возможность настраивать правила безопасности, без необходимости доступа к персональному компьютеру.

При разработке клиентской части целесообразно использовать кроссплатформенные технологии, позволяющие реализовать пользовательский интерфейс сразу для нескольких операционных систем на базе единого исходного кода, для этого можно использовать технологию React Native. Данное мобильное приложение должно включать в себя:

- Регистрацию нового пользователя;
- Вход в личный кабинет;
- Предоставление информации о сетевой активности клиента: визуализация в виде графика и расчет суммарного объема входящего и исходящего трафика за заданный временной интервал; отображение перечня стран и доменов, с которыми осуществлялось взаимодействие;
- Просмотр сведений об учетной записи пользователя с возможностью загрузки VPN-конфигурации на устройство;
- Формирование таблицы, содержащей сведения о выявленных угрозах в сетевом трафике за определенный период времени;
- Возможность создания и редактирования пользователей черных списков стран и доменов.

Вывод по параграфу 2.2

Таким образом, реализация клиентской части в виде мобильного приложения позволяет существенно повысить удобство взаимодействия пользователя с системой за счет возможности оперативного управления черными списками и просмотра информации о сетевой активности. В ходе проектирования клиентской части системы был обоснован выбор разработки кроссплатформенного мобильного приложения с использованием технологии React Native. Предложен перечень функционала, который необходимо реализовать в данном блоке программного комплекса.

Вывод по второй главе

В ходе проектирования архитектуры многоуровневой системы защиты были выполнены следующие работы: 1. Спроектирована серверная архитектура, включающая OpenVPN для изолированного перехвата пользовательского трафика, базу данных SQLite для структурированного хранения журналов событий и REST API для обмена данными с клиентской частью; 2. Определен конвейер анализа сетевого трафика с использование инструмента Zeek и его

расширений; 3. Разработана подсистема поведенческого профилирования, работающая на основе алгоритма машинного обучения без учителя; 4. Сформулированы требования к клиентской части и спроектирован функционал кроссплатформенного мобильного приложения;

Спроектированная архитектура многоуровневой системы защиты позволяет создать комплексное решение, объединяющее методы статического анализа и машинного обучения для эффективного мониторинга трафика и защиты пользователей от вредоносной сетевой активности.

1. Статистика утечек данных за 2025 год [Электронный ресурс]. F6. URL: https://www.f6.ru/media-center/press-releases/cyberthreats-2025/ (дата обращения: 10.10.2026).
2. Рост использования инструментов для организации защищенного доступа [Электронный ресурс]. Коммерсантъ. URL: https://www.kommersant.ru/doc/8624480 (дата обращения: 10.10.2026).
3. Актуальные киберугрозы: Россия [Электронный ресурс]. Positive Technologies. URL: https://ptsecurity.com/research/analytics/russia-cyberthreat-landscape-2026/ (дата обращения: 10.10.2026).
4. Применение методов машинного обучения для выявления аномалий в сетевом трафике [Электронный ресурс]. Cyberleninka. URL: https://cyberleninka.ru/article/n/primenenie-metodov-mashinnogo-obucheniya-dlya-vyyavleniya-anomaliy-v-setevom-trafike/viewer (дата обращения: 10.10.2026).
5. Машинное обучение с учителем и без: как выбрать правильный подход для вашего проекта [Электронный ресурс]. Сбербанк. URL: https://sberbs.ru/blogs/blog/mashinnoe-obuchenie-s-uchitelem-i-bez (дата обращения: 10.10.2026).
6. О Zeek [Электронный ресурс]. Zeek. URL: https://zeek.org/about/ (дата обращения: 10.10.2026).
7. Improving Time Series Prediction Models Using Cyclic Features Encoding in Neural Networks [Электронный ресурс]. Medium. URL: https://medium.com/@dhanyahari07/improving-time-series-prediction-models-using-cyclic-features-encoding-in-neural-networks-0eebef307fc2 (дата обращения: 10.10.2026).
8. Доля рынка трафика с мобильных устройств в сравнении с настольными компьютерами и планшетами [Электронный ресурс]. Similarweb. URL: https://www.similarweb.com/ru/platforms/ (дата обращения: 10.10.2026).